

Regulated Data



Nancy LaTourrette, CISSP
Computer Science & Engineering

Privacy Laws & Regulations

"Although privacy often has been said to mean "the right to be let alone,"¹ the application of this concept in modern times is by no means straightforward. Consumers live in a world where information about their purchasing behavior, online browsing habits, and other online and offline activity is collected, analyzed, combined, used, and shared, often instantaneously and invisibly."

-- FTC Staff Report, Protecting Consumer Privacy In An Era Of Rapid Change, 2010

¹ Samuel D. Warren & Louis D. Brandeis, *The Right to Privacy*, 4 Harv. L. Rev. 193, 193 (1890).

Data Regulations & Standards

Privacy laws and regulations pertain to the rights and obligations of individuals and organizations in regards to data assets.

- The threat, and reality, of security breaches has led to laws, regulations, and standards to prevent the the loss or misuse of personal data.
- Organizations must comply with regulations to **protect the data assets collected, shared, stored or processed.**
- Organizations must be familiar with the laws and regulations protecting these data assets.
- Several types of **data have been identified and classified for special protection.**

Regulated Data Classifications

Important data classifications, applicable laws and standards:

- Personally Identifiable Information (PII)

- Sarbanes-Oxley and Gramm-Leach-Bliley Acts

- Protected Health Information (PHI)

- Health Insurance Portability & Accountability Act (HIPAA)

- Payment Card Industry [Data] (PCI)

- Payment Card Industry Data Security Standard (PCI DSS)

- Student Education Records

- The Federal Family Educational Rights and Privacy Act of 1974 (FERPA)

Data Protection Standards (ISO)

The ISO 27000 family of standards helps organizations manage the security of information assets.

- **Information assets** include financial information, intellectual property, employee details or information entrusted by third parties.
- Standards range from **requirements** for information security management systems, controls, measurement and risk management to auditing.
- The 27000 group of standards **also addresses specific industries** and related data such as energy utilities, cloud services and health informatics.

Data Protection Standards (NIST)

NIST Special Publication 800-122 – provides guidelines for a risk-based approach to protecting the confidentiality of Personally Identifiable Information (PII).

- **Identify** all PII residing in an organization's environment.
- **Minimize** the use, collection, and retention of PII.
- **Categorize** PII by confidentiality impact level and apply appropriate safeguards based on that level.
- **Develop** an incident response plan to handle PII breaches.
- **Coordination** among C-level officers regarding all PII issues.

Sarbanes-Oxley Act

*The Sarbanes-Oxley Act of 2002 is a federal law which establishes **requirements for financial systems**, to deter fraud and increase corporate accountability.*

- Sections 302 and 404 of Sarbanes-Oxley indirectly force the scrutiny of information security controls for compliance.

- **Section 302** - compliance requirements to **list all deficiencies** in internal controls and information; **report fraud** involving internal employees.

- **Section 404** – requirements to **assess the effectiveness of internal controls**; outside auditors; report assessment annually to the SEC.

Gramm-Leach-Bliley Act

*The Gramm-Leach-Bliley Act requires financial institutions to **explain their information-sharing practices** to customers and to safeguard sensitive data.*

- **Financial Privacy Rule** – a required **privacy notice** of institutional privacy practices: information collection; information sharing; and safeguarding the information.
- **The Safeguards Rule** - requires financial institutions to **secure customer records** and information to protect confidentiality and maintain integrity.
- **Pretexting Provisions** – **protects consumers** from personal financial information obtained under fraudulent circumstances.

Health Insurance Portability & Accountability Act (HIPAA)

*Health Insurance Portability & Accountability Act (HIPAA) is United States legislation that provides data privacy and security provisions for **safeguarding medical information**.*

- **Privacy Rule** – requires safeguards to protect the privacy of PHI; **sets limits and conditions** on the uses and disclosures without patient authorization.
- **Security Rule** - establishes **national standards** to protect electronic PHI that is created, received, used, or maintained by a covered entity.
- **Enforcement Rule** - contains **provisions relating to compliance and penalties**. HITECH Act addresses privacy and security concerns associated with **transmission of PHI**.

Payment Card Industry Data Security Standard (PCI DSS)

*The Payment Card Industry Data Security Standard (PCI DSS) provides a **baseline of technical and operational requirements** designed to protect account data.*

- Build and maintain a **secure network** and systems
- **Protect** cardholder data
- Maintain a vulnerability **management program**
- Implement strong **access control measures**
- Regularly **monitor and test** networks
- Maintain an **information security policy**

Family Educational Rights and Privacy Act (FERPA)

*Family Educational Rights and Privacy Act (FERPA) is a federal law that protects the **privacy of student education records**.*

- FERPA **rights regarding education records:**

- Inspect and Review

- Access

- Challenge the Content

- Consent to Disclosure

- FERPA **initially grants the rights to parents.**

- **Rights transfer to eligible students** when they:

- attain 18 years of age, or

- attend a postsecondary education institution.

Acknowledgement

This material is based upon work supported by the National Science Foundation under Grant No. 1516724.



References

- [1] ISO 27000, INFORMATION SECURITY MANAGEMENT SYSTEMS,
[https://www.iso.org/obp/ui/ - iso:std:iso-iec:27000:ed-4:v1:en](https://www.iso.org/obp/ui/- iso:std:iso-iec:27000:ed-4:v1:en)
- [2] NIST SP 800-122, GUIDE TO PROTECTING THE CONFIDENTIALITY OF PERSONALLY IDENTIFIABLE INFORMATION (PII),
<http://csrc.nist.gov/publications/nistpubs/800-122/sp800-122.pdf>
- [3] SARBANES-OXLEY ACT OF 2002,
http://legcounsel.house.gov/Comps/Sarbanes-oxley_Act_Of_2002.pdf
- [4] GRAMM-LEACH-BLILEY ACT, <https://www.gpo.gov/fdsys/pkg/PLAW-106publ102/pdf/PLAW-106publ102.pdf>
- [5] PAYMENT CARD INDUSTRY DATA SECURITY STANDARD,
https://www.pcisecuritystandards.org/documents/PCI_DSS_v3-2.pdf?agreement=true&time=1470701891969
- [6] HEALTH INSURANCE PORTABILITY AND ACCOUNTABILITY ACT OF 1996,
<https://www.gpo.gov/fdsys/pkg/PLAW-104publ191/pdf/PLAW-104publ191.pdf>

References (cont'd)

[7] FAMILY EDUCATIONAL RIGHTS AND PRIVACY ACT, <http://www.ecfr.gov/cgi-bin/text-idx?rgn=div5&node=34:1.1.1.1.33>

[8] UC BERKELEY, SCHOOL OF INFORMATION - KNOW PRIVACY, http://www.knowprivacy.org/report/KnowPrivacy_Final_Report.pdf

[9] FTC STAFF REPORT – PROTECTING CONSUMER PRIVACY IN AN ERA OF RAPID CHANGE, <https://www.ftc.gov/reports/preliminary-ftc-staff-report-protecting-consumer-privacy-era-rapid-change-proposed-framework>